

claude-windows / ce5ec24b-cf40-49bb-afb0-3a41f4cc9934

Metadata

```
- Source: `claude-windows`  
- Kind: `claude`  
- Source file: `C:\Users\avidu\.claude\projects\C--Users-avidu-Projects-badminton-highlight-indexer\ce5ec24b-cf40-49bb-afb0-3a41f4cc9934\subagents\workflows\wf_2be29ecf-a31\agent-ae113fa42ad2b5ef6.jsonl`  
- SHA-256: `5ccb449db6470e028c522ecea97ae1682cc079760d47f821cbd0200c2a1375`  
- Source modified: `2026-06-22T01:29:08+00:00`  
- Imported at: `2026-07-05T16:48:23+00:00`  
- project: `wf_2be29ecf-a31`  
- session_id: `ce5ec24b-cf40-49bb-afb0-3a41f4cc9934`
```

Transcript

1. user (2026-06-22T01:28:08.300Z)

Adversarially verify this P2b-install review finding. Read the cited code in C:\Users\avidu\Projects\bhi-p2b yourself (run `cd C:\Users\avidu\Projects\bhi-p2b && git diff origin/master...HEAD` and open the file). Decide if it is a REAL defect that should block or be fixed, or a false alarm / nit. Default to is_real=false if it does not hold up.

Lens: safety-dataloss

Severity(claimed): major

Title: uninstall.py deletes manifest 'created'/'user_data' paths verbatim with NO containment check ? a corrupted/edited/foreign manifest can rmtree an arbitrary directory (incl. on a default, non-purge run)

File: scripts/uninstall.py

Detail: The manifest is plain JSON read from disk (main(), line 94) and is fully user-editable / corruptible / swappable via --manifest. Its 'created' list is deleted on EVERY uninstall (lines 119-122, not just --purge), and 'user_data' on --purge (lines 124-127), by passing each path straight to _rm() -> shutil.rmtree (lines 68-79). Nothing verifies these paths live under app_home. If 'created' (or 'user_data') ever contains a broad path ? e.g. a hand-edit, a future installer bug, a stale manifest from a different/old app-home, or app_home itself ? a plain `python uninstall.py` (no --purge) will rmtree it. _rm only guards against symlinked dirs, not against a too-broad/outside-app-home real directory. This is the classic 'trust the deletion manifest blindly' data-loss vector and should not depend on the manifest being pristine. The deletion orchestration (main/_rm) is also entirely untested ? tests/test_p2b_install.py only exercises pure helpers (build_manifest/shortcut_spec/argv), never a real or adversarial deletion.

Suggested fix: Before deleting, resolve app_home and refuse any path that is not strictly contained within it. Add a guard in _rm (or at the call sites) like: `rp = path.resolve(); ah = app\_home.resolve(); if rp == ah or not rp.is\_relative\_to(ah): print('refusing to remove path outside app-home'); return` ? and additionally refuse to rmtree app_home itself, the filesystem root, or the user home. Apply to BOTH the 'created' loop and the --purge 'user_data' loop. Add a test that feeds a manifest whose 'created'/'user_data' contains an outside-app-home dir and asserts it is NOT removed.

2. assistant (2026-06-22T01:28:11.097Z)

I'll verify this finding by examining the actual code in the cited repository.

3. user (2026-06-22T01:28:14.706Z)

78e423d docs(pkg): link P2b-install PR #310 in the \$7 tracker

a5c1493 feat(pkg): P2b-install ? batteries-included install + truly-local 'motion' first-run default (gate 08)

4. user (2026-06-22T01:28:14.892Z)

```

backend/config/__init__.py | 9 +-
backend/config/loader.py | 34 +++++++
backend/main.py | 15 +++
docs/PACKAGING_PLAN.md | 13 +-
scripts/install.py | 210 +++++
scripts/uninstall.py | 150 +++++
tests/test_app_launcher.py | 42 +++++
tests/test_p2b_install.py | 163 +++++
9 files changed, 660 insertions(+), 7 deletions(-)

```

5. assistant (2026-06-22T01:28:17.107Z)

Now let me read the full uninstall.py file.

6. user (2026-06-22T01:28:17.997Z)

```

1      #!/usr/bin/env python3
2      """Clean uninstaller for the KhelSutra highlight indexer (PACKAGING_PLAN.md P2b).
3
4      Reverses ``scripts/install.py`` from the manifest it wrote:
5
6      * uninstalls the package (``uv tool uninstall`` / ``pip uninstall -y`` ? matches the
install method);
7      * removes the files the installer created (launcher shortcut, the copied uninstaller,
the manifest);
8      * by default **KEEPS your data** (the seeded ``config.json``, your ``.env`` with the
Gemini key,
9      and the ``output/`` reels + DB). Pass ``--purge`` to delete those too.
10
11      Usage::
12
13      python uninstall.py                # find the manifest in the app-home, keep user
data
14      python uninstall.py --purge        # also delete config.json / .env / output (your
data)
15      python uninstall.py --manifest /path/to/uninstall_manifest.json
16      python uninstall.py --dry-run      # print the plan, change nothing
17
18      stdlib-only; safe to run from the copy the installer dropped in the app-home.
19      """
20      from __future__ import annotations
21
22      import argparse
23      import json
24      import os
25      import platform
26      import shutil
27      import subprocess
28      import sys
29      from pathlib import Path
30
31      APP_DIR_NAME = "Khelsutra"
32      MANIFEST_NAME = "uninstall_manifest.json"
33
34
35      def default_os_app_home(app_name: str = APP_DIR_NAME, system: str | None = None,
36                              env: dict[str, str] | None = None) -> Path:
37          """Mirror of the installer's app-home resolver (used to LOCATE the manifest when not
given)."""
38          system = system or platform.system()
39          e = os.environ if env is None else env
40          if system == "Windows":
41              base = e.get("APPDATA") or str(Path.home() / "AppData" / "Roaming")
42          elif system == "Darwin":
43              base = str(Path.home() / "Library" / "Application Support")

```

```

44         else:
45             base = e.get("XDG_DATA_HOME") or str(Path.home() / ".local" / "share")
46             return Path(base) / app_name
47
48
49     def find_manifest(explicit: str | None) -> Path | None:
50         """The manifest path: explicit arg, else next to THIS file, else the default app-
51         home."""
52         if explicit:
53             p = Path(explicit)
54             return p if p.exists() else None
55         for cand in (Path(__file__).resolve().parent / MANIFEST_NAME,
56                     default_os_app_home() / MANIFEST_NAME):
57             if cand.exists():
58                 return cand
59         return None
60
61     def uninstall_command(method: str, package: str) -> list[str]:
62         """The argv to remove the package (PURE)."""
63         if method == "uv":
64             return ["uv", "tool", "uninstall", package]
65         return [sys.executable, "-m", "pip", "uninstall", "-y", package]
66
67
68     def _rm(path: Path, dry: bool) -> None:
69         try:
70             if path.is_dir() and not path.is_symlink():
71                 print(f" - rmtree {path}")
72                 if not dry:
73                     shutil.rmtree(path, ignore_errors=True)
74             elif path.exists() or path.is_symlink():
75                 print(f" - remove {path}")
76                 if not dry:
77                     path.unlink(missing_ok=True)
78         except OSError as e:
79             print(f" ! could not remove {path}: {e}")
80
81
82     def main(argv: list[str] | None = None) -> int:
83         ap = argparse.ArgumentParser(description="Uninstall the KhelSutra highlight
84         indexer.")
85         ap.add_argument("--manifest", default=None, help="Path to uninstall_manifest.json.")
86         ap.add_argument("--purge", action="store_true",
87         help="Also delete YOUR data (config.json, .env, output/). Default
88         keeps it.")
89         ap.add_argument("--dry-run", action="store_true", help="Print the plan; change
90         nothing.")
91         args = ap.parse_args(argv)
92
93         manifest_path = find_manifest(args.manifest)
94         if not manifest_path:
95             print("[ERROR] no uninstall_manifest.json found (pass --manifest <path>).")
96             return 1
97         manifest = json.loads(manifest_path.read_text(encoding="utf-8"))
98         method = manifest.get("install_method", "pip")
99         package = manifest.get("package", "badminton-highlight-indexer")
100         created = [Path(p) for p in manifest.get("created", [])]
101         user_data = [Path(p) for p in manifest.get("user_data", [])]
102         app_home = Path(manifest.get("app_home", str(manifest_path.parent)))
103
104         print(f"KhelSutra uninstaller ? {package} (installed via {method})")
105         print(f" manifest : {manifest_path}")
106         print(f" app-home : {app_home}")
107         print(f" data      : {'WILL BE DELETED (--purge)' if args.purge else 'kept (use"}

```

```

--purge to delete}')")
105     dry = args.dry_run
106
107     print("\n[1/3] removing the package?")
108     cmd = uninstall_command(method, package)
109     print(f" $ {' '.join(cmd)}")
110     if not dry:
111         try:
112             subprocess.run(cmd, check=False)
113         except FileNotFoundError as e:
114             print(f" ! {method} not found ({e}); remove the package manually.")
115
116     print("\n[2/3] removing installer-created files?")
117     # Remove the manifest LAST (we still reference it); skip the running uninstaller
copy itself.
118     self_path = Path(__file__).resolve()
119     for p in created:
120         if p.resolve() == self_path or p.resolve() == manifest_path.resolve():
121             continue
122         _rm(p, dry)
123
124     if args.purge:
125         print("\n[3/3] purging user data (--purge)?")
126         for p in user_data:
127             _rm(p, dry)
128     else:
129         print("\n[3/3] keeping your data:")
130         for p in user_data:
131             print(f" · {p}")
132
133     # Manifest + (optionally) the empty app-home last.
134     _rm(manifest_path, dry)
135     if args.purge and app_home.exists():
136         try:
137             remaining = [c for c in app_home.iterdir() if c.resolve() != self_path]
138             if not remaining:
139                 _rm(app_home, dry)
140         except OSError:
141             pass
142
143     print("\n? Uninstalled." + (" " if args.purge else " Your data was kept. "))
144     if self_path.parent == app_home:
145         print(f" (you can delete this script + the app-home folder manually:
{app_home})")
146     return 0
147
148
149 if __name__ == "__main__":
150     raise SystemExit(main())
151

```

7. assistant (2026-06-22T01:28:20.862Z)

Now let me look at how install.py builds the manifest to understand what `created` and `user\_data` actually contain.

8. user (2026-06-22T01:28:21.737Z)

```

1     #!/usr/bin/env python3
2     """Batteries-included installer for the KhelSutra highlight indexer (PACKAGING_PLAN.md
P2b).
3
4     Cross-platform (Windows / macOS / Linux), no native component (01):
5
6     * installs the LIGHT (torch-free) package via ``uv tool install`` (preferred ? an

```

```

isolated tool
7         env that puts ``indexer`` on PATH) or ``pip install`` (fallback);
8         * creates a per-OS launcher shortcut that pins ``RALLY_APP_HOME`` to the OS app-data
dir and runs
9         ``indexer --app`` ? so config / .env / DB / reels live in ONE stable place
10        (mirrors ``backend.utils.app_home.default_os_app_home``). Pinning the env BEFORE the
process
11        starts is load-bearing: the engine's ``load_dotenv`` runs at import, so only an env
set by the
12        launcher (not by the engine) roots the ``.env`` in the app-home;
13        * writes an uninstall manifest so ``scripts/uninstall.py`` can cleanly reverse it.
14
15        The truly-local + ``motion`` default config is seeded by the ENGINE itself on the first
16        ``indexer --app`` run (``write_light_default_config``), so it works regardless of
install method;
17        this script only wires the install + the launcher.
18
19        Usage::
20
21        python scripts/install.py                # install '.' (this checkout), uv-
if-present else pip
22        python scripts/install.py --target badminton-highlight-indexer  # from PyPI (once
published)
23        python scripts/install.py --method pip      # force pip
24        python scripts/install.py --dry-run         # print the plan, change nothing
25
26        stdlib-only so it runs as a standalone bootstrap BEFORE the package exists.
27        """
28        from __future__ import annotations
29
30        import argparse
31        import json
32        import os
33        import platform
34        import shutil
35        import subprocess
36        import sys
37        from datetime import datetime, timezone
38        from pathlib import Path
39
40        PACKAGE = "badminton-highlight-indexer"
41        APP_DIR_NAME = "Khelsutra" # mirrors backend.utils.app_home.APP_DIR_NAME
42        MANIFEST_NAME = "uninstall_manifest.json"
43
44
45        # --- pure helpers (unit-tested)
-----
46
47        def default_os_app_home(app_name: str = APP_DIR_NAME, system: str | None = None,
48                                env: dict[str, str] | None = None) -> Path:
49            """The OS-conventional per-user app-data dir ? a standalone mirror of
50            ``backend.utils.app_home.default_os_app_home`` (this script runs before the package
exists)."""
51            system = system or platform.system()
52            e = os.environ if env is None else env
53            if system == "Windows":
54                base = e.get("APPDATA") or str(Path.home() / "AppData" / "Roaming")
55            elif system == "Darwin":
56                base = str(Path.home() / "Library" / "Application Support")
57            else:
58                base = e.get("XDG_DATA_HOME") or str(Path.home() / ".local" / "share")
59            return Path(base) / app_name
60
61
62        def shortcut_spec(system: str, app_home: Path, indexer_cmd: str = "indexer") ->

```

```

tuple[str, str, bool]:
63     """Return `(filename, content, make_executable)` for the per-OS launcher shortcut.
64
65     The shortcut pins `RALLY_APP_HOME` then runs `indexer --app`. PURE (no IO) so
it's testable.
66     """
67     home = str(app_home)
68     if system == "Windows":
69         content = (
70             "@echo off\r\n"
71             "rem KhelSutra launcher (PACKAGING_PLAN.md P2b) ? pins app-home then opens
the app.\r\n"
72             f'set "RALLY_APP_HOME={home}"\r\n'
73             f'{indexer_cmd} --app\r\n"
74         )
75         return "KhelSutra.bat", content, False
76     if system == "Darwin":
77         content = (
78             "#!/bin/bash\n"
79             "# KhelSutra launcher (PACKAGING_PLAN.md P2b) ? pins app-home then opens the
app.\n"
80             f'export RALLY_APP_HOME="{home}"\n'
81             f"exec {indexer_cmd} --app\n"
82         )
83         return "KhelSutra.command", content, True
84     # Linux / other
85     content = (
86         "#!/bin/bash\n"
87         "# KhelSutra launcher (PACKAGING_PLAN.md P2b) ? pins app-home then opens the
app.\n"
88         f'export RALLY_APP_HOME="{home}"\n'
89         f"exec {indexer_cmd} --app\n"
90     )
91     return "khelsutra.sh", content, True
92
93
94     def build_manifest(*, method: str, app_home: Path, shortcut: Path, created: list[Path],
95                       timestamp: str) -> dict:
96         """The uninstall manifest (PURE). `created` = files THIS installer made (safe to
remove);
97         `user_data` = paths the engine/user own (kept unless `uninstall.py --purge`)."""
98         return {
99             "schema": 1,
100             "product": "KhelSutra highlight indexer",
101             "package": PACKAGE,
102             "install_method": method,          # "uv" | "pip"
103             "indexer_command": "indexer",
104             "app_home": str(app_home),
105             "shortcut": str(shortcut),
106             "created": [str(p) for p in created],
107             "user_data": [
108                 str(app_home / "config.json"),
109                 str(app_home / ".env"),
110                 str(app_home / "output"),
111             ],
112             "timestamp": timestamp,
113         }
114
115
116     def resolve_method(requested: str, uv_present: bool) -> str:
117         """Pick the installer: explicit beats auto; auto prefers uv when present, else
pip."""
118         if requested in ("uv", "pip"):
119             return requested
120         return "uv" if uv_present else "pip"

```

```

121
122
123     def install_command(method: str, target: str) -> list[str]:
124         """The argv for the chosen installer (PURE)."""
125         if method == "uv":
126             return ["uv", "tool", "install", target]
127         return [sys.executable, "-m", "pip", "install", target]
128
129
130     # --- IO / orchestration
131     -----
132
133     def _run(argv: list[str]) -> None:
134         print(f" $ {' '.join(argv)}")
135         subprocess.run(argv, check=True)
136
137     def main(argv: list[str] | None = None) -> int:
138         ap = argparse.ArgumentParser(description="Install the KhelSutra highlight indexer
139 (LIGHT tier).")
140         ap.add_argument("--target", default=".",
141                         help="What to install: '.' (this checkout, default) or a PyPI
142 name/spec.")
143         ap.add_argument("--method", choices=("auto", "uv", "pip"), default="auto",
144                         help="Installer to use (default: uv if present, else pip).")
145         ap.add_argument("--dry-run", action="store_true", help="Print the plan; change
146 nothing.")
147         args = ap.parse_args(argv)
148
149         system = platform.system()
150         app_home = default_os_app_home()
151         method = resolve_method(args.method, shutil.which("uv") is not None)
152         cmd = install_command(method, args.target)
153         fname, content, executable = shortcut_spec(system, app_home)
154         shortcut = app_home / fname
155
156         print(f"KhelSutra installer ? {PACKAGE} (LIGHT, torch-free)")
157         print(f" OS      : {system}")
158         print(f" installer : {method}")
159         print(f" target    : {args.target}")
160         print(f" app-home   : {app_home}")
161         print(f" shortcut   : {shortcut}")
162         if args.dry_run:
163             print("\n[dry-run] would run:")
164             print(f" $ {' '.join(cmd)}")
165             print(f" write shortcut -> {shortcut}")
166             print(f" write manifest -> {app_home / MANIFEST_NAME}")
167             print(f" copy uninstaller -> {app_home / 'uninstall.py'}")
168             return 0
169
170         print("\n[1/3] installing the package?")
171         try:
172             _run(cmd)
173         except (subprocess.CalledProcessError, FileNotFoundError) as e:
174             print(f"[ERROR] install failed: {e}")
175             if method == "uv":
176                 print(" (uv not usable? re-run with --method pip)")
177             return 1
178
179         print("\n[2/3] writing the launcher shortcut + app-home?")
180         app_home.mkdir(parents=True, exist_ok=True)
181         shortcut.write_text(content, encoding="utf-8")
182         if executable:
183             shortcut.chmod(0o755)
184         # Make the uninstaller available next to the data it removes.

```

```

182         created: list[Path] = [shortcut]
183         here = Path(__file__).resolve().parent
184         src_uninstall = here / "uninstall.py"
185         dst_uninstall = app_home / "uninstall.py"
186         if src_uninstall.exists():
187             shutil.copyfile(src_uninstall, dst_uninstall)
188             created.append(dst_uninstall)
189
190         print("\n[3/3] writing the uninstall manifest?")
191         manifest_path = app_home / MANIFEST_NAME
192         created.append(manifest_path)
193         manifest = build_manifest(
194             method=method, app_home=app_home, shortcut=shortcut, created=created,
195             timestamp=datetime.now(timezone.utc).isoformat(timespec="seconds"),
196         )
197         manifest_path.write_text(json.dumps(manifest, indent=2) + "\n", encoding="utf-8")
198
199         print("\n? Installed. To launch KhelSutra:")
200         if system == "Windows":
201             print(f"    double-click {shortcut}    (or run `indexer --app`)")
202         else:
203             print(f"    {shortcut}    (or run `indexer --app`)")
204         print("    The first run seeds a truly-local 'motion' config (offline, no key/GPU
needed).")
205         print(f"    To uninstall: python \"{dst_uninstall}\"    (add --purge to also delete
your data)")
206         return 0
207
208
209     if __name__ == "__main__":
210         raise SystemExit(main())
211

```

9. assistant (2026-06-22T01:28:24.038Z)

Now let me check the test file to verify the claim that deletion orchestration is untested.

10. user (2026-06-22T01:28:24.841Z)

```

1     """P2b-install (PACKAGING_PLAN.md): batteries-included config seeding +
install/uninstall tooling.
2
3     Covers:
4     * the engine-side ``write_light_default_config`` (gate 08 default = truly-local +
motion), incl.
5     the load-bearing **no-overwrite** idempotency and the EFFECTIVE config the loader
produces;
6     * the pure logic of ``scripts/install.py`` / ``scripts/uninstall.py`` (shortcut
content, manifest,
7     installer/uninstaller argv, method resolution, OS app-home) ? no real subprocess/IO.
8     """
9     from __future__ import annotations
10
11     import importlib.util
12     import json
13     from pathlib import Path
14
15     import pytest
16
17     from backend.config import LIGHT_DEFAULT_CONFIG, load_config, write_light_default_config
18
19
20     def _load_script(name: str):
21         """Load a scripts/*.py bootstrap file as a module (it is stdlib-only, safe to
exec)."""

```



```

22     path = Path(__file__).resolve().parents[1] / "scripts" / name
23     spec = importlib.util.spec_from_file_location(name[:-3], path)
24     assert spec and spec.loader
25     mod = importlib.util.module_from_spec(spec)
26     spec.loader.exec_module(mod)
27     return mod
28
29
30     # --- engine seeding: write_light_default_config (gate 08)
-----
31
32     def test_seed_writes_truly_local_motion(tmp_path):
33         cfg = tmp_path / "sub" / "config.json" # also proves parent-dir creation
34         path, written = write_light_default_config(cfg)
35         assert written is True and path == cfg and cfg.exists()
36         data = json.loads(cfg.read_text(encoding="utf-8"))
37         assert data == LIGHT_DEFAULT_CONFIG
38         assert data["indexing"]["default_segmenter"] == "motion"
39         assert data["indexing"]["use_gpu"] is False
40         assert data["deployment"]["profile"] == "truly-local"
41
42
43     def test_seed_does_not_overwrite_existing(tmp_path):
44         cfg = tmp_path / "config.json"
45         cfg.write_text('{"sport": "tennis", "indexing": {"default_segmenter": "gemini"}}',
encoding="utf-8")
46         path, written = write_light_default_config(cfg)
47         assert written is False and path == cfg
48         # The user's file is preserved untouched (the wizard/edits are never clobbered).
49         assert json.loads(cfg.read_text(encoding="utf-8"))["indexing"]["default_segmenter"]
== "gemini"
50
51
52     def test_seed_overwrite_true_forces(tmp_path):
53         cfg = tmp_path / "config.json"
54         cfg.write_text("{}", encoding="utf-8")
55         _, written = write_light_default_config(cfg, overwrite=True)
56         assert written is True
57         assert json.loads(cfg.read_text(encoding="utf-8")) == LIGHT_DEFAULT_CONFIG
58
59
60     def test_seeded_config_loads_to_truly_local_motion(tmp_path):
61         """The minimal seeded file, run through the loader, expands via the truly-local
PRESET to a
62         coherent torch-free/offline config (motion + no Gemini handoff + local storage + no
GPU)."""
63         cfg = tmp_path / "config.json"
64         write_light_default_config(cfg)
65         loaded = load_config(cfg)
66         assert loaded.indexing.default_segmenter == "motion"
67         assert loaded.indexing.use_gpu is False
68         assert loaded.deployment.profile == "truly-local"
69         assert loaded.indexing.skip_ai_handoff is True # supplied by the truly-local
preset
70         assert loaded.storage.backend == "local" # supplied by the truly-local
preset
71
72
73     # --- scripts/install.py pure logic
-----
74
75     @pytest.fixture(scope="module")
76     def install_mod():
77         return _load_script("install.py")
78

```

```

79
80 @pytest.fixture(scope="module")
81 def uninstall_mod():
82     return _load_script("uninstall.py")
83
84
85 @pytest.mark.parametrize(
86     "system, fname, executable",
87     [("Windows", "KhelSutra.bat", False), ("Darwin", "KhelSutra.command", True),
88      ("Linux", "khelsutra.sh", True)],
89 )
90 def test_shortcut_spec_per_os(install_mod, system, fname, executable):
91     home = Path("/home/u/AppHome")
92     name, content, ex = install_mod.shortcut_spec(system, home)
93     assert name == fname and ex is executable
94     # str(home) is OS-native (backslashes on windows) ? assert against it, not a
hardcoded literal.
95     assert "RALLY_APP_HOME" in content and str(home) in content
96     assert "indexer --app" in content
97
98
99 def test_resolve_method(install_mod):
100     assert install_mod.resolve_method("auto", uv_present=True) == "uv"
101     assert install_mod.resolve_method("auto", uv_present=False) == "pip"
102     assert install_mod.resolve_method("pip", uv_present=True) == "pip" # explicit wins
103     assert install_mod.resolve_method("uv", uv_present=False) == "uv"
104
105
106 def test_install_command_argv(install_mod):
107     assert install_mod.install_command("uv", ".") == ["uv", "tool", "install", "."]
108     pip = install_mod.install_command("pip", "badminton-highlight-indexer")
109     assert pip[1:] == ["-m", "pip", "install", "badminton-highlight-indexer"]
110
111
112 def test_default_os_app_home_per_os(install_mod):
113     win = install_mod.default_os_app_home(system="Windows", env={"APPDATA":
r"C:\Users\u\AppData\Roaming"})
114     assert win.name == "Khelsutra" and "Roaming" in str(win)
115     lin = install_mod.default_os_app_home(system="Linux", env={"XDG_DATA_HOME":
"/home/u/.local/share"})
116     assert str(lin) == str(Path("/home/u/.local/share") / "Khelsutra")
117
118
119 def test_build_manifest_shape(install_mod):
120     home = Path("/home/u/AppHome")
121     m = install_mod.build_manifest(
122         method="uv", app_home=home, shortcut=home / "khelsutra.sh",
123         created=[home / "khelsutra.sh", home / "uninstall_manifest.json"],
timestamp="2026-06-22T00:00:00+00:00",
124     )
125     assert m["package"] == "badminton-highlight-indexer"
126     assert m["install_method"] == "uv"
127     assert str(home / "config.json") in m["user_data"] # user data is tracked
separately (kept on uninstall)
128     assert m["shortcut"] == str(home / "khelsutra.sh")
129     assert m["schema"] == 1
130
131
132 # --- scripts/uninstall.py pure logic
-----
133
134 def test_uninstall_command_argv(uninstall_mod):
135     assert uninstall_mod.uninstall_command("uv", "badminton-highlight-indexer") == \
136         ["uv", "tool", "uninstall", "badminton-highlight-indexer"]
137     pip = uninstall_mod.uninstall_command("pip", "badminton-highlight-indexer")

```

```

138         assert pip[1:] == ["-m", "pip", "uninstall", "-y", "badminton-highlight-indexer"]
139
140
141     def test_find_manifest_explicit(uninstall_mod, tmp_path):
142         m = tmp_path / "uninstall_manifest.json"
143         m.write_text("{} ", encoding="utf-8")
144         assert uninstall_mod.find_manifest(str(m)) == m
145         assert uninstall_mod.find_manifest(str(tmp_path / "nope.json")) is None
146
147
148     def test_install_uninstall_roundtrip_manifest(install_mod, uninstall_mod, tmp_path):
149         """The manifest install.py would write is consumable by uninstall.py's
150         expectations."""
151         home = tmp_path / "AppHome"
152         m = install_mod.build_manifest(
153             method="pip", app_home=home, shortcut=home / "KhelSutra.bat",
154             created=[home / "KhelSutra.bat", home / "uninstall_manifest.json"],
155             timestamp="2026-06-22T00:00:00+00:00",
156         )
157         mp = home / "uninstall_manifest.json"
158         home.mkdir(parents=True)
159         mp.write_text(json.dumps(m), encoding="utf-8")
160         assert uninstall_mod.find_manifest(str(mp)) == mp
161         loaded = json.loads(mp.read_text(encoding="utf-8"))
162         assert uninstall_mod.uninstall_command(loaded["install_method"],
163             loaded["package"])[0:3] in (
164             ["uv", "tool", "uninstall"], [install_mod.sys.executable, "-m", "pip"],
165         )
166

```

11. assistant (2026-06-22T01:28:42.509Z)

I have now read all the relevant code. Let me analyze the finding carefully.

The finding's factual claims are accurate:

- `manifest` is plain JSON read from disk (line 94) ? true.
- `--manifest` is fully user-supplyable (line 84) ? true.
- `created` paths deleted on EVERY uninstall (lines 119-122) ? true.
- `user\_data` deleted only on `--purge` (lines 124-127) ? true.
- `\_rm` -> `shutil.rmtree` (lines 68-73), only guards against symlinked dirs ? true.
- No containment check against `app\_home` ? true. `app\_home` is read but only used for display (lines 99, 104) and the final empty-dir cleanup (line 135).
- Tests only exercise pure helpers, never `main`/`\_rm` deletion ? true.

Now the adversarial lens ? is this a REAL defect that should block/be fixed, or a false alarm / nit?

Let me weigh the realism of the threat model:

1. ****Who writes the manifest?**** The installer (`install.py`) writes it with `created` = `[shortcut, dst\_uninstall, manifest\_path]` ? all narrowly scoped under `app\_home`, and `user\_data` = three specific paths under `app\_home`. So in the normal install/uninstall flow, every path is already contained. The danger only materializes with a corrupted/hand-edited/foreign/swapped manifest.
2. ****Is this a "trust the deletion manifest blindly" data-loss vector?**** Yes, structurally. A defense-in-depth containment check is a well-established, cheap, standard hardening for uninstallers that rmtree from a manifest. This matches a real security/safety pattern.
3. ****Severity calibration.**** The claimed severity is "major." Let me consider counterarguments to that:
 - The trigger requires a non-pristine manifest (corruption, manual edit, a future installer bug, or pointing `--manifest` at a stale/foreign manifest). This is not the normal path ? it's a "if something else goes wrong, this amplifies it" hardening gap.
 - However, the repo's own conventions explicitly elevate exactly this class: "loud failures,

no silent drops," "data-loss" sensitivity, and the launch-quality bar. An uninstaller that can `rmtree` an arbitrary directory (including `app\_home` itself, or a broad path) on a plain non-purge run is a genuine data-loss footgun. The "default (non-purge) run can still delete" angle is correct ? `created` is deleted unconditionally.

Let me double check the one nuance the finding raises: can `created` realistically contain `app\_home` itself or a broad path? In the current installer, no. But the finding's point is about robustness against a non-pristine manifest, which is the legitimate concern for a destructive tool. The `\_rm` only skips symlinked dirs, and `ignore\_errors=True` on `rmtree` means it won't even error out partway ? it'll silently delete what it can.

Let me verify there's genuinely no containment guard anywhere (e.g., in a helper I might have missed) and confirm `is\_relative\_to` availability given the Python 3.8+ requirement.

12. user (2026-06-22T01:28:44.517Z)

```
35: def default_os_app_home(app_name: str = APP_DIR_NAME, system: str | None = None,
54:     for cand in (Path(__file__).resolve().parent / MANIFEST_NAME,
55:         default_os_app_home() / MANIFEST_NAME):
99:     app_home = Path(manifest.get("app_home", str(manifest_path.parent)))
103:     print(f"  app-home : {app_home}")
118:     self_path = Path(__file__).resolve()
120:     if p.resolve() == self_path or p.resolve() == manifest_path.resolve():
135:     if args.purge and app_home.exists():
137:         remaining = [c for c in app_home.iterdir() if c.resolve() != self_path]
139:         _rm(app_home, dry)
144:     if self_path.parent == app_home:
145:         print(f"  (you can delete this script + the app-home folder manually: {app_home})")
```

13. user (2026-06-22T01:28:45.643Z)

```
pyproject.toml:21:requires-python = ">=3.10"
```

14. assistant (2026-06-22T01:28:51.234Z)

This confirms the analysis. Two important findings:

1. ****No containment guard exists**** ? `app\_home` is read but used only for display (lines 103, 145) and the trailing empty-dir cleanup (lines 135-139). The deletion loops (`created`, `user\_data`) pass paths straight to `\_rm` with no relative-to-`app\_home` check.
2. ****The suggested fix is implementable**** ? `requires-python = ">=3.10"` for the package. `Path.is\_relative\_to` was added in Python 3.9, so the suggested guard works. (Minor caveat: the install/uninstall scripts are "stdlib-only bootstrap" scripts that run before the package, but they target the same Python; 3.10+ is a safe assumption, and a fallback is trivial.)

I have enough to render a verdict.

15. user (2026-06-22T01:29:02.322Z)

Structured output provided successfully

16. assistant (2026-06-22T01:29:08.878Z)

Verdict: ****REAL but minor**** (downgraded from the claimed major).

The finding is factually accurate on every point I checked in

`C:\Users\avidu\Projects\bhi-p2b\scripts\uninstall.py`:

- The manifest is untrusted input (plain JSON, `--manifest`-supplyable, line 94 / line 84).
- `created` is deleted unconditionally on every run (lines 119-122); `user\_data` on `--purge` (lines 124-127); both via `\_rm` ? `shutil.rmtree` with `ignore\_errors=True` (lines 68-73).
- There is genuinely no containment check ? `app\_home` (line 99) is used only for display and the trailing empty-dir cleanup, never as a deletion boundary.
- The deletion orchestration is untested; `tests/test\_p2b\_install.py` only covers pure helpers.

The suggested ``is_relative_to(app_home)`` guard is feasible (``requires-python >=3.10``).

I downgraded the severity because the only writer of these manifests, ``install.py::build_manifest`` (lines 94-113), scopes both lists to narrow, specific files under ``app_home``, so the normal install/uninstall flow is already safe. Data loss requires a non-pristine/foreign manifest containing a broad path ? a real "trust the deletion manifest blindly" hardening gap worth fixing in this PR, but not a defect that fires under documented usage, so it should not block as a major.